

Type d'attaques

Stéphane Gill

Stephane.Gill@CollegeAhuntsic.qc.ca

Table des matières

Introduction.....	2
Les attaques d'accès.....	2
Le sniffing.....	2
Les chevaux de Troie.....	3
Porte dérobée.....	3
L'ingénierie sociale.....	3
Le craquage de mots de passe.....	4
Les attaques de modification.....	4
Virus, vers et chevaux de Troie.....	4
Les attaques par saturation (déni de service).....	5
Le flooding	5
Le TCP-SYN flooding	5
Le smurf	6
Le débordement de tampon	6
Les attaques de répudiation.....	6
Le IP spoofing	6
Références.....	6

Document écrit par Stéphane Gill

© Copyright 2013 Stéphane Gill

Ce document est soumis à la licence GNU FDL.

Permission vous est donnée de distribuer, modifier des copies de ce document tant que cette note apparaît clairement.

Introduction

Les informations ou les systèmes d'informations d'une entreprise peuvent subir des dommages de plusieurs façons : certains intentionnels (malveillants), d'autres par accident. Ces événements seront appelés des « attaques ».

Il existe quatre catégories principales d'attaque :

- L'accès;
- La modification;
- La saturation;
- La répudiation.

Les attaques peuvent être réalisées grâce à des moyens techniques ou par ingénierie sociale. L'ingénierie sociale consiste à employer des méthodes non techniques pour obtenir un accès non autorisé.

Les attaques d'accès

Une attaque d'accès est une tentative d'accès à l'information par une personne non autorisée. Ce type d'attaque concerne la confidentialité de l'information.

Le sniffing

Cette attaque est utilisée par les pirates informatiques pour obtenir des mots de passe. Grâce à un logiciel appelé renifleur de paquets (sniffer), on peut intercepter toutes les paquets qui circulent sur un réseau même ceux qui ne nous sont pas destinés. Par exemple, lors d'une connexion grâce à « telnet » le mot de passe de l'utilisateur va transiter en clair sur le réseau. Il est aussi possible de savoir à tout moment quelles pages web regardent les personnes connectées au réseau, les sessions ftp en cours, les mails en envoi ou réception. Cette technologie n'est pas forcément illégale car elle permet aussi de détecter des failles sur un système.

Les chevaux de Troie

Les chevaux de Troie sont des programmes informatiques cachés dans d'autres programmes. Ce nom vient de la légende grecque de la prise de Troie à l'aide d'un cheval en bois rempli de soldats qui attaquèrent la ville une fois à l'intérieur.

En général, le but d'un cheval de Troie est de créer une porte dérobée (backdoor) pour qu'un pirate informatique puisse ensuite accéder facilement l'ordinateur ou le réseau informatique. Il peut aussi voler des mots de passe, copier des données, exécuter des actions nuisibles.

Porte dérobée

Lorsqu'un pirate informatique arrive à accéder à un serveur à l'aide d'une des techniques présentées dans cette section, il souhaiterait y retourner sans avoir à tout recommencer. Pour cela, il laisse donc des portes dérobées (backdoor) qui lui permettront de reprendre facilement le contrôle du système informatique.

Il existe différents types de portes dérobées :

- Création d'un nouveau compte administrateur avec un mot de passe choisi par le pirate.
- Création de compte ftp
- Modification des règles du pare-feu pour qu'il accepte des connexions externes.

Dans tous les cas, l'administrateur perd le contrôle total du système informatique. Le pirate peut alors récupérer les données qu'il souhaite, voler des mots de passe ou même détruire des données.

L'ingénierie sociale

L'ingénierie sociale (social engineering en anglais) n'est pas vraiment une attaque informatique, c'est plutôt une méthode pour obtenir des informations sur un système ou des mots de passe.

Elle consiste surtout à se faire passer pour quelqu'un que l'on est pas (en général un des administrateurs du serveur que l'on veut pirater) et de demander des informations personnelles

(login, mots de passe, accès, numéros, données...) en inventant un quelconque motif (plantage du réseau, modification de celui-ci...). Elle se fait soit au moyen d'une simple communication téléphonique ou par courriel.

Le craquage de mots de passe

Le craquage consiste à faire de nombreux essais jusqu'à trouver le bon mot de passe.

Il existe deux grandes méthodes :

- **L'utilisation de dictionnaires** : le mot testé est pris dans une liste prédéfinie contenant les mots de passe les plus courants et aussi des variantes de ceux-ci (à l'envers, avec un chiffre à la fin...). Les dictionnaires actuels contiennent dans les 50 000 mots et sont capables de faire une grande partie des variantes.
- **La méthode brute** : toutes les possibilités sont faites dans l'ordre jusqu'à trouver la bonne solution.

Les attaques de modification

Une attaque de type « modification » consiste, pour un attaquant à tenter de modifier des informations. Ce type d'attaque est dirigé contre l'intégrité de l'information.

Virus, vers et chevaux de Troie

Il existe une grande variété de virus. On peut cependant définir un virus comme un programme caché dans un autre qui peut s'exécuter et se reproduire en infectant d'autres programmes ou d'autres ordinateurs.

Les dégâts causés vont du simple programme qui affiche un message à l'écran au programme qui formate le disque dur après s'être multiplié. On ne classe cependant pas les virus d'après leurs dégâts mais selon leur mode de propagation et de multiplication :

- Les vers capables de se propager dans le réseau;
- Les « chevaux de Troie » créant des failles dans un système;
- Les bombes logiques se lançant suite à un événement du système;

- Les canulars envoyés par mail.

Les attaques par saturation (dénî de service)

Les attaques par saturation sont des attaques informatiques qui consiste à envoyer des milliers de messages depuis des dizaines d'ordinateurs, dans le but de submerger les serveurs d'une société, de paralyser pendant plusieurs heures son site Web et d'en bloquer ainsi l'accès aux internautes.

Cette technique de piratage assez simple à réaliser est jugées comme de la pure malveillance. Elle ne fait que bloquer l'accès aux sites, sans en altérer le contenu.

Il existe différente attaque par saturation :

- Le flooding
- Le TCP-SYN flooding
- Le smurf
- Le débordement de tampon

Le flooding

Cette attaque consiste à envoyer à une machine de nombreux paquets IP de grosse taille. La machine cible ne pourra donc pas traiter tous les paquets et finira par se déconnecter du réseau.

Le TCP-SYN flooding

Le TCP-SYN flooding est une variante du flooding qui s'appuie sur une faille du protocole TCP . En effet, on envoie un grand nombre de demande de connexions au serveur (SYN) à partir de plusieurs machines. Le serveur va envoyer un grand nombre de paquet SYN-ACK et attendre en réponse un paquet ACK qui ne viendra jamais. Si on envoie les paquets plus vite que le timeout des « demi-connexion » (connexions autorisées mais non terminé), le serveur sature et finit par se déconnecter.

Le smurf

Le smurf est une attaque qui s'appuie sur le ping et les serveurs de broadcast . On falsifie d'abord son adresse IP pour se faire passer pour la machine cible. On envoie alors un ping sur un serveur de broadcast. Il le fera suivre à toutes les machines qui sont connectées qui renverront chacune un « pong » au serveur qui fera suivre à la machine cible. Celle-ci sera alors inondée sous les paquets et finira par se déconnecter.

Le débordement de tampon

Cette attaque se base sur une faille du protocole IP. On envoie à la machine cible des données d'une taille supérieure à la capacité d'un paquet. Celui-ci sera alors fractionné pour l'envoi et rassemblé par la machine cible. A ce moment, il y aura débordement des variables internes.

Suite à ce débordement, plusieurs cas se présentent : la machine se bloque, redémarre ou ce qui est plus grave, écrit sur le code en mémoire.

Les attaques de répudiation

La répudiation est une attaque contre la responsabilité. Autrement dit, la répudiation consiste à tenter de donner de fausses informations ou de nier qu'un événement ou une transaction se soient réellement passé.

Le IP spoofing

Cette attaque consiste à se faire passer pour une autre machine en falsifiant son adresse IP. Elle est en fait assez complexe. Il existe des variantes car on peut spoofer aussi des adresses e-mail, des serveurs DNS ou NFS.

Références

Donald L. Pipkin, « Sécurité des systèmes d'information », CampusPress, 2000.

Thomas W. Shinder, « Sécurité sous Windows 2000 Server », Eyrolles, 2002.

Type d'attaques

Stefen Norberg, « Securing Windows NT/2000 Servers for the Internet », O'Reilly, 2001.

Elizabeth Zwicky, Simon Cooper et Brent Chapman, « Building Internet Firewalls », deuxième édition, O'Reilly, 2000.

Eric Maiwald, « Sécurité des réseaux », Campus press, 2001.

Aron Hsiao, « Sécurité sous Linux », Campus press, 2001.